2026 Shenzhen International FinTech Competition

International Track | Topic F Agent Wallet

mandate.

Security Self-Assessment

Permissions, safeguards and remaining risks

ChainSentinel Bangladesh

TEAM MEMBERS

MD ARIF SHEKH — Team Leader
Computer Science and Engineering | Undergraduate Year 4
International University of Business Agriculture and Technology (IUBAT)

MD MEHERAB HOSSAIN TALUKDER — Team Member
Computer Science and Engineering | Undergraduate Year 4
International University of Business Agriculture and Technology (IUBAT)

IRIN KHATUN — Team Member
Accounting & Information Systems | Undergraduate Year 4
Jagannath University

20 October 2026

Local chain and Ethereum Sepolia | Synthetic bills and MDT test tokens

01 Permission Model

This assessment examines who can authorize an action, how that authority is constrained and which trust remains outside the controls. It is a team review of the implemented prototype. The Technical Report explains the component design; Execution Evidence contains measured outcomes and receipts.

Role	Allowed operations	Enforced boundary
Owner	Register vendors; approve exact bills; set spending/access rules; cancel, pause or revoke.	Owner-only contract methods; signatures remain in the browser wallet.
AI model	Suggest invoice fields, intent, clarification or correction.	Validated data proposals; no signing interface or administrative contract operation.
Agent	Submit the vault's fixed payment call for approved bill keys.	Cannot approve bills, modify stored destinations/amounts or administer the vault.
Workspace user	Review drafts, ask the assistant and confirm plans.	Shared app access; owner-chain changes still require the owner wallet.

Approval and execution boundaries

An approval binds the bill key, recipient, amount, document hash, vendor revision and payment window in contract storage. Invoice instructions and database flags cannot create that permission. payBill reads the stored details and checks caller identity, policy version, active windows, bill/vendor state, spending caps and reserve. Paid keys cannot be re-approved to clear replay protection. [S1, S2]

The owner reviews exact details before a wallet signature; a later execution plan needs its own confirmation. These application checks express user intent. The contract independently checks stored authority, but cannot determine the meaning of a conversation. A wrongly approved bill can still be an authorized payment.

Changes recovery and finality

Editing or deleting a draft does not cancel an existing chain approval. The owner must sign cancellation or replacement. Pending or unknown transaction outcomes remain locked for reconciliation; the app never treats a timeout as permission for another send. A failed token transfer reverts its associated paid/spending state, while an already-mined transfer cannot be rolled back by the application. [S2]

The owner can recover tokens only while paused; that owner-only operation intentionally bypasses agent budgets. The owner and token addresses are immutable, with no owner-key rotation or recovery in this version. Stop ordering and finality risks are addressed in the risk section rather than assuming an immediate rollback.

02 Threats and Security Tests

The test design challenges each enforcement layer with a specific failure or abuse attempt. The table maps threats to the existing requirement and test-group IDs. Execution Evidence is the single location for suite counts, evaluation denominators, exceptions and public-network outcomes.

Threat	Control and verification approach
Prompt injection or social engineering	Treat invoice text as data. Reject unknown bill IDs, arbitrary calls and unexpected model fields. Exercise read-only, no-payment and ambiguous requests. F07/F09; R12/R15.
Privilege escalation or overspending	Call contracts directly to challenge owner/agent roles, changed recipients and amounts. Check one-unit limit/reserve boundaries and cumulative daily accounting. C01–C03/C06; R03–R06.
Replay or concurrent execution	Reuse bill keys and plans; start simultaneous executor objects; reopen saved state. Assert at most one successful transfer per approved key. C04/F06; R07/R11.
Stale permission or time window	Change policy after planning and between sends. Check cancellation, pause, revocation, before-start and expiry boundaries independently. C05/C06; R08/R09.
Token callback or transfer failure	Test reentrancy attempts, failed transfers and inexact balance changes. Verify atomic rollback and matching events. C06; R05/R11.
Malicious file or browser/API request	Validate input type/size and ambiguous fields; render hostile text inertly; require expected Host/Origin and CSRF for writes. F01/F02/F08; R01/R02/R13/R14.
Receipt outage or cloud-state conflict	Inject unknown broadcast outcomes, mismatched receipts, lost saves, wrong decryption keys and stale revisions. Confirm work stops safely and recovery follows original hashes. F06 and hosting checks; R07/R11/R13.

Evidence interpretation

Model-free tests establish application handling of controlled proposals. Live-model cases examine interpretation in the integrated workflow. Public receipts establish particular recorded transactions, while eth_call rejections are unmined simulations. These evidence types support different conclusions and are not interchangeable. [S3]

The required release gate is no unresolved unauthorized-transfer, duplicate-payment or secret-exposure issue within the defined tests. A finite set of passing cases is not complete attack coverage. The measured misses, repairs and public revocation-scope qualification remain beside their results in Execution Evidence.

Test sources: TESTING.md (C01–C06, F01–F09); test/agent.test.mjs; contract tests under test/; test/hosting*.test.mjs. Requirement IDs are unchanged.

03 Data and Privacy

Provenance and external processing

The team created the demonstration invoices and vendor records. For AI assistance, the app submits the requested invoice text or a user message with bounded bill summaries to Groq. It does not provide signers, credentials or arbitrary transaction tools. Provider processing and retention terms still apply; the prototype does not establish zero retention or local-only processing. Real invoice use would need a separate consent and handling review. [S1, S2]

Stored data and deletion

Raw upload bytes are discarded after parsing. SQLite retains extracted text, drafts, messages, proposals and reconciliation records. Removing a source deletes linked text/drafts/proposals and removes invoice labels from retained payment records. Minimal opaque references and receipts remain. Deletion cannot undo provider processing, copied data, backups or immutable chain records.

Hosted snapshots use AES-256-GCM with random nonces and workspace-bound authenticated data. Neon stores the ciphertext; the encryption secret resides in private Render configuration. The running service uses a plaintext SQLite working file with restricted permissions. A compromised application host can access decrypted data and runtime secrets. [S4]

Authentication and browser access

The gateway requires HTTPS and the shared workspace password. Signed sessions use Secure, HttpOnly and SameSite=Strict cookies, expire after eight hours and are invalidated by logout or process restart. Requests must satisfy the configured Host/Origin checks; authenticated changes also require the application CSRF token. A restrictive content policy and escaped text reduce script-injection exposure.

Reviewer access is the full shared workspace. It has no individual accounts, MFA or read-only role. Repeated wrong passwords receive HTTP 429, but password checking is not delayed and there is no durable lockout. These are prototype controls, not robust abuse throttling. Access instructions belong to competition/JUDGE_REVIEW.md. [S4]

Keys and source handover

The owner key stays in the browser wallet. The separate persistent agent key is stored locally as ignored plaintext JSON with owner-only permissions and configured privately on the backend. API, session and storage secrets also remain server-side. This is not encrypted signing infrastructure. Source delivery excludes credentials, local databases and registration identity material; pattern scanning supplements human inspection.

Provider failures leave manual review available. The implementation does not automatically retry, switch provider/model or enable billing. A third-party service remains responsible for its own processing terms; dependency licenses are listed in the source handover notices.

04 Known Risks

Each item below states the remaining exposure, the current boundary and the work needed before broader use. These improvements are not implemented features or an independent security certification.

Host key or shared-login compromise

A stolen agent key can spend all approvals that remain valid within their bounds. A password holder can use the full app. Narrow approvals, expiry and confirmed revocation limit authority; stronger identity controls, effective abuse throttling and protected signing infrastructure are priorities.

Incorrect review and changed identifiers

The vault verifies permission, not invoice authenticity or delivery. Human review can approve a wrong bill, and different invoice/vendor identifiers may evade exact-key duplicate checks. Source review and similar-ID warnings help. Identity checks and review usability need broader validation.

RPC finality and stop ordering

RPC responses and transaction inclusion remain external dependencies. Matching receipts and pinned configuration reduce certain mistakes, but the configured confirmation threshold does not guarantee finality. A stop may be ordered after a pending payment. Broader wallet compatibility, independent RPC checks and a documented finality policy are future work.

Availability and loss of recovery material

Hosting inactivity, provider limits or storage failure can interrupt access. Revision checks and encrypted snapshots preserve the tested recovery path, while uncertainty blocks further work. They do not establish immutable backups or comprehensive disaster recovery. Loss of the storage secret can make snapshots unreadable; loss of the immutable owner can strand assets.

Model generalisation and reporting quality

Language guards are conservative application rules, not universal intent understanding. Results on repaired fixed cases do not establish performance on unseen invoices or human productivity. New layouts, fresh evaluation cases and human review studies remain necessary. The exact observed errors and comparison limits are recorded once in Execution Evidence.

Scope and trust

The implementation supports its fixed demo token and permitted test networks. Block timestamps define access and UTC-day boundaries; they are not a precise scheduler or rolling-day cap. Arbitrary or dishonest token implementations, real-fund operation and licensed payment-service use are outside this assessment.

[S1] REQUIREMENTS.md and SECURITY.md. [S2] contracts/MandateVault.sol; app/model.mjs, service.mjs, agent.mjs, executor.mjs and store.mjs. [S3] TESTING.md and the saved runs indexed in Execution Evidence. [S4] scripts/hosting/gateway.mjs, persistence.mjs and start.mjs; hosting tests and evidence/HOSTING_RESULTS.md.